

침해사고 대응지침



주식회사 모인

개정 이력

[illegible]

침해사고 대응지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)의 침해사고에 대비한 사항을 규정하는 정책시행 문서로서 침해사고 발생 또는 사고징후 포착 시 신속한 대응을 통하여 피해를 최소화하기 위한 기준으로써 활용함을 그 목적으로 한다.

제2조(적용 범위) 이 지침은 침해사고와 관련된 모든 인력과 정보자산을 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

1. “사이버위협”이란 함은 해킹, 컴퓨터바이러스, 악성메일, 악의적인 실행코드, 서비스방해 등 전자적 수단에 의하여 정보통신망을 불법 침입, 교란, 마비, 파괴하기 위해 위협을 하는 행위를 의미한다.
2. “악성코드”(또는 “컴퓨터악성코드”)라 함은 컴퓨터에서 이용자의 허락 없이 스스로를 복사하거나 변형한 뒤 정보유출, 시스템 파괴 등의 작업을 수행하여 이용자에게 피해를 주는 프로그램을 의미한다.
3. “해킹”이라 함은 접근을 허가 받지 아니하고 전자금융기반시설에 불법적으로 침투하거나 허가 받지 아니한 권한을 불법적으로 갖는 행위 또는 전자금융기반시설을 공격하거나 해를 끼치는 행위를 의미한다.
4. “침해사고”라 함은 바이러스, 트로이 목마, 백도어, 악의적인 공격 스크립트 등을 유포, 설치 및 실행으로 피해를 유발하는 악성 코드 공격, 비 인가된 시스템 접근 및 파일 접근, 네트워크 정보수집을 포함한 비 인가된 네트워크 정보 접근, 네트워크 서비스의 취약점을 이용하여 서비스를 무단 이용하는 비 인가된 서비스 이용, 네트워크 및 시스템의 정상적인 서비스를 마비 또는 파괴시키는 서비스 방해 등의 전자적 침해 사고를 의미한다.
5. “보안관제”라 함은 보안 및 장애 이벤트를 모니터링 및 탐지하여 침해사고로 발생되는 피해를 최소화하고, 사고에 대한 신속한 대응을 하기 위한 활동을 의미한다.
6. “금융정보교환망(이하 “FINES” 라 한다)”이라 함은 금융감독원에서 금융회사 또는 전자금융업자를 대상으로 전자금융 사고 등을 보고하기 위해 지원하는 망을 의미한다.

제2장 역할 및 책임

제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO” 라 한다)는 침해사고 대응에 대한 정책을 수립하고, 정책의 이행을 위하여 필요한 자원을 지원할 책임을 갖는다.
- 2 CISO는 침해사고 발생 시 침해사고 대응팀장으로서 침해사고 대응 관련 업무와 조직을 지휘하는 역할을 수행한다.

제5조(정보보호 담당자)

- 1 정보보호 담당자는 침해사고 발생 시 원인, 영향, 파급범위 파악 등의 활동을 수행하고, 그 결과를 CISO에게 보고하여야 한다.
- 2 정보보호 담당자는 침해사고에 대한 모의훈련을 수행하고, 결과를 분석한다.

제6조(보안관제 담당자)

- 1 보안관제 담당자는 보안관제 및 분석대응을 수행하고, 침해사고 이상징후 발생 시 정보보안팀(이하 “보안팀”)에 보고하여야 한다.
- 2 보안관제 담당자는 24시간 내 유입 네트워크 트래픽 모니터링 및 사고 발생시 초동조치를 수행한다.

제3장 침해사고 대응 체계

제7조(침해사고 심각도 및 보고)

- 1 회사는 정보자산에 영향을 미치는 침해사고의 심각도는 ‘정상’, ‘경계’, ‘심각’의 3단계로 구분한다.
- 2 CISO는 ‘경계’ 단계 이상의 침해사고의 경우 지체 없이 대표이사에게 보고 및 통지를 진행하고, 침해사고가 ‘심각’ 단계인 경우 다음 각 호의 사항을 수행한다.
 - 1) 금융감독원 FINES 시스템을 통해 사고보고
 - 2) 개인신용정보 유출의 경우, 정보주체에게 유출 항목, 시점, 경위, 피해 최소화 방법, 회사의 대응조치 및 피해구제절차, 피해신고 방법안내 등 관련 내용을 문자 등으로 지체 없이 통지 (5일 이내)

제8조(침해사고 유형) 회사에서 적극적인 대응이 필요하다고 판단하는 침해사고의 유형은 다음 각 호와 같다.

- 1) 악성코드 공격(바이러스, 백도어, 트로이 목마 등)
- 2) 분산 서비스거부 공격(디도스, DDoS)
- 3) 비인가접근에 의한 공격(불법 권한취득, 데이터 위·변조, 정보유출 등)

제9조(침해사고 대응체계 구축) 회사는 침해사고를 모니터링하고 대응할 수 있도록 다음 각 호의 내용을

포함하여 중앙 집중적인 대응체계를 구축하여야 하며, 외부 전문기관에 위탁하여 수행할 수 있다.

- 1) 대응조직 및 인력
- 2) 모니터링 및 대응방법
- 3) 모니터링 및 대응절차
- 4) 모니터링 및 대응보고 및 승인 방법

제10조(비상연락체계) 회사는 침해사고에 대비하여 금융위원회, 금융감독원, 금융보안원, 한국인터넷진흥원, 유지보수 업체 등 관계기관과 적절한 협력관계를 구축하여야 하며, 비상연락체계를 마련하여야 한다.

제4장 침해사고 대응

제11조(침해사고 탐지)

1 보안관제 담당자는 침해사고를 탐지하기 위해 다음 각 호의 이벤트를 활용하여 사이버 위협에 대한 통합 모니터링을 수행한다.

- 1) 방화벽, IPS, DDoS대응, WAF 등 네트워크 구간 보안솔루션 이벤트
- 2) 접근통제시스템 이벤트(서버/DB 등)
- 3) 회사의 서비스 제공 웹/앱 위·변조 탐지 시스템 이벤트
- 4) 그 외 필요하다고 인정되는 시스템 이벤트

2 보안관제 담당자는 제1항에 따라 침해사고 징후를 파악하거나, 보안 정책(rule-set)에 의해 침해 행위가 탐지된 경우 관련 절차에 따라 신속하게 조치한다.

제12조(침해사고 신고 및 접수)

1 누구든지 바이러스 및 해킹사고가 의심되는 이상 징후를 탐지하거나, 보안관제 담당자가 통합 모니터링 중 침해사고로 판단되는 경우 즉시 보안팀에 통보하여야 한다.

2 보안팀은 피해 정도를 파악하여 침해사고 여부를 판단하고, 침해사고 심각도가 '경계' 단계 이상이라고 판단되는 경우 CISO에게 즉시 보고한다.

3 CISO는 침해사고 심각도, 공격 유형 및 피해 규모 등을 고려하여 침해사고 대응팀을 소집할 수 있다.

제13조(침해사고 분석)

1 정보보호 담당자는 침해사고와 관련한 로그를 백업하는 등 필요한 조치를 취하고, 다음 각 호를 고려하여 침해사고 원인을 분석한다.

- 1) 특별한 장소 또는 행위로부터의 접속에 대한 로그파일 조사

- 2) 시스템 바이너리 파일의 변경여부 조사
 - 3) 인가받지 않은 프로그램 또는 서비스 등의 사용 조사
 - 4) 시스템과 네트워크 설정 파일의 인가받지 않은 항목 조사
 - 5) 시스템에 숨겨지거나 특이한 파일이 있는지 조사
- 2 CISO는 정보보호 담당자에게 침해사고 대응 및 복구를 지시하고, 필요 시 비상연락체계를 가동한다.
- 3 회사는 침해사고 원인파악 및 대응이 자체적으로 처리하기 어려운 경우 금융보안원, 한국인터넷진흥원 또는 민간 전문기관에 의뢰할 수 있다.

제14조(침해사고 대응 및 복구)

- 1 정보보호 담당자는 침해 행위가 추가적으로 발생하거나 재발할 가능성이 있는 경우, 다음 각 호와 같은 필요한 조치를 즉시 취한다.
 - 1) 접속을 추적하고, 내부 단말기에서 침투한 경우 현재의 단말기 위치를 확인한 후 조치를 취한다.
 - 2) 역 추적이 가능한 경우 상대방 시스템을 확인한 후 침입자의 의도나 요구사항을 알아본다.
 - 3) 침입자 전자메일 주소를 파악한 경우 경고 메시지를 전송하여 침입의지를 격감시킨다.
 - 4) 접속을 차단한다.
- 2 정보보호 담당자는 침입자 추적이 어렵거나, 해킹으로부터 시스템의 보호가 우선되는 경우 접속을 즉시 차단한다.
- 3 정보보호 담당자는 침해사고 발생 원인을 파악하면 즉시 다음 각 호와 같은 필요한 조치를 취한다.
 - 1) 피해 시스템으로부터 악성코드의 제거, 프로그램의 재설치, 보안업데이트의 적용, 관리자계정 비밀번호 변경
 - 2) 백업 미디어의 악성코드 감염 여부 확인 및 제거 등
- 4 그 외 세부 대응사항과 침해사고 대응팀 및 유관부서의 대응조치 사항은 「침해사고 대응 매뉴얼」을 따른다.

제15조(침해사고 기록 및 보고) 정보보호 담당자는 침해사고 발생 일시, 사고내용, 사고처리 등을 기록한 <침해사고(장애) 대응 결과보고서>을 작성하고 1년 이상 보존한다.

제16조(침해사고 통지)

- 1 회사는 전자금융기반시설이 교란·마비되는 등의 침해사고가 발생한 때에는 금융위원회에 지체 없이 이를 보고하여야 하며, 보고는 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다.
- 2 제1항에 따라 보고할 때에는 사고 내용, 사고에 따른 영향 등을 침해사고 통지보고 서식에 따라 기재한다

제17조(정보기술부문 및 전자금융 사고보고)

- 1 회사는 정보기술부문 및 전자금융과 관련된 사고에 관하여 다음 각 호를 준수하여야 한다.
 - 1) 사고의 유형 분류, 처리단계, 조치방법, 영향도 및 심각도 평가 방법 등이 포함된 절차를 마련·운영.
 - 2) 금융감독원장이 정하는 사고가 발생한 경우에는 지체없이 금융감독원장에게 보고
- 2 회사는 제1항에 따른 사고보고를 고의로 지연하였거나 숨긴 자에 대하여 소정절차에 따라 징계 등 필요한 조치를 취한다.
- 3 제1항의 사고보고와 관련하여 사고보고 대상은 아래 각 호와 같다.
 - 1) 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우
 - (1) 전자금융업무 지연·중단 시간이 30분 이상인 경우
 - (2) 전자금융업무 지연·중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우
 - 2) 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우
 - 3) 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 회사에게 통지한 경우
 - 4) 다음 각 호의 어느 하나에 해당하는 사고로 인하여 이용자에게 손해가 발생할 경우
 - (1) 접근매체의 위조나 변조로 발생한 사고
 - (2) 계약체결 또는 거래지시의 전자적 전송이나 처리 과정에서 발생한 사고
 - (3) 전자금융거래를 위한 전자적 장치 또는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망에 침입하여 거짓이나 그 밖의 부정한 방법으로 획득한 접근매체의 이용으로 발생한 사고
- 4 제3항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고 대상에서 제외한다.
 - 1) 제3항제1호에 해당하는 사고 중 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융업무 중단·지연
 - 2) 제3항제1호에 해당하는 사고 중 이용자에게 단순 정보 제공을 위한 공개용 웹서버 등의 장애 또는 금융상품 및 서비스와 무관한 장애
 - 3) 제3항제4호제1목 또는 제3목의 사고가 발생하였으나 사고금액이 100만원 미만인 경우
- 5 제3항의 사고가 발생한 경우 정보기술부문 및 전자금융 사고보고서 서식에 따라 지체 없이 보고하여야 하며, 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. 다만 제3항제4호제1목 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 일괄 보고 서식에 따라 보고 일괄 보고할 수 있다.
- 6 제5항의 사고보고와 관련하여 사고보고 절차와 방법은 아래 각 호와 같다.

- 1) 최초보고 : 사고를 인지 또는 발견한 때로부터 24시간 이내에 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 보고한다. 단, 전산장애, 금융정보교환망 미연결 등 부득이한 경우에는 서면, 팩시밀리 또는 유선으로 보고할 수 있으며, 이 경우에 전자금융사고대응시스템(EFARS)으로 보고가능한 즉시 전자금융사고대응시스템(EFARS)으로 보고한다.
- 2) 중간보고 : 제1호의 최초보고 후 사고내용을 보완할 필요가 있는 경우에는 즉시 중간보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지·발견일로부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 최초보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다
- 3) 종결보고 : 사고발생 원인 파악 및 조치, 재발방지 대책 마련 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다.
- 4) 회사는 제3항의 규정에 따른 책임을 이행하기 위하여 금융위원회가 정하는 기준에 따라 보험 또는 공제에 가입하거나 준비금을 적립하는 등 필요한 조치를 하여야 한다

제18조(대외연락에 대한 역할과 책임)

- 1 CISO는 침해사고 발생 시 대외에 전달할 메시지를 작성하고 검토한다.
- 2 미디어는 커뮤니케이션팀, 제휴사/가맹점 등에 대한 커뮤니케이션의 책임은 파트너십 담당자가 맡는다.
- 3 보안팀은 금융보안원과 한국인터넷진흥원의 협조를 요청하는 역할을 수행하고, 침해사고 발생 이전에도 위협정보 공유체계 등을 통하여 협조체제를 유지한다.
- 4 개인(신용)정보의 유출 사고 발생에 따른 대응계획 수립, 유출 통지 및 신고 등의 절차는 「개인(신용)정보보호지침」에서 정한 바에 따른다.

제19조(지속적 개선)

- 1 회사는 침해사고 재발방지를 위한 대책을 다음 각 호의 사항들을 포함하여 수립하고, 임직원에게 공유한다.
 - 1) 침해사고 주요 내용
 - 2) 사고 대응 및 조치 방법
 - 3) 재발방지대책
 - 4) 사용자가 수행하여야 할 조치사항 등
- 2 보안팀은 침해사고 대응 지침 및 관련 절차의 실효성·적정성 등을 매년 1회 이상 점검하여 최신 상태로

유지하고 관리하여야 한다.

제20조(침해사고 대응 훈련)

- 1 회사는 다음 각 호의 내용을 반영하여 연 1회 이상 침해사고 대응 및 복구훈련(이하 '침해사고대응훈련'이라 한다) 계획을 수립하고 시행하며, 그 결과를 침해사고대응기관의 장에게 제출한다.
 - 1) 내/외부의 침해사고 유형 및 내용
 - 2) 발생할 수 있는 사고 시나리오
 - 3) 대응방안
- 2 침해사고대응훈련은 디도스, 악성코드, 해킹 등 3개의 분야에 맞게 시나리오를 구성하고 실시한다.
- 3 고객정보가 저장된 네트워크를 대상으로 하여 내/외부로부터 침입을 시도하는 모의해킹(penetration test)을 매년 1회 이상 실시한다.
- 4 침해사고대응훈련, 모의해킹, 취약점점검 결과는 3년간 보존한다.

제21조(클라우드서비스 사고대응)

- 1 회사는 클라우드서비스를 이용하고자 하는 경우 클라우드서비스 제공자가 다음 각 호의 사항을 실시할 수 있도록 계약서 내에 명시하여야 한다.
 - 1) 사고 발생 시 신고 절차, 복구 및 대응 절차 등을 마련
 - 2) 주기적으로 침해사고 대응훈련 실시
 - 3) 관련 직원을 모두 포함한 비상연락체계 마련
 - 4) 복구목표시간 및 복구목표시점 사전 합의
 - 5) 사고 발생 시 즉시 회사에 통지
 - 6) 사고 조사 및 피해 복구 적극 협조
- 2 회사는 제1항 제2호에 따른 클라우드서비스 제공자의 침해사고 대응 훈련 시 필요한 경우 공동 훈련을 실시할 수 있다.
- 3 회사는 제1항 제6호에 따른 사고 조사를 위해 클라우드서비스 제공자가 필요한 주요 데이터(로그, 가상화 이미지 등)를 회사에 제공할 수 있도록 기술적 방안 마련을 요구하여야 한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.